ZNEXORA TECH | SECURITY BRIEFING

macOS Security Hardening

Protecting enterprise Macs through secure configuration

A practical guide for system administrators and security teams

Apple Platform Security Guide | CIS Benchmarks | NIST mSCP



Presented by: **ZNexora Tech** · [Presenter] · [Date]

“Macs don’t get malware” is a myth

Infostealers
Atomic (AMOS) and similar stealers take Keychain items, browser cookies and crypto wallets.

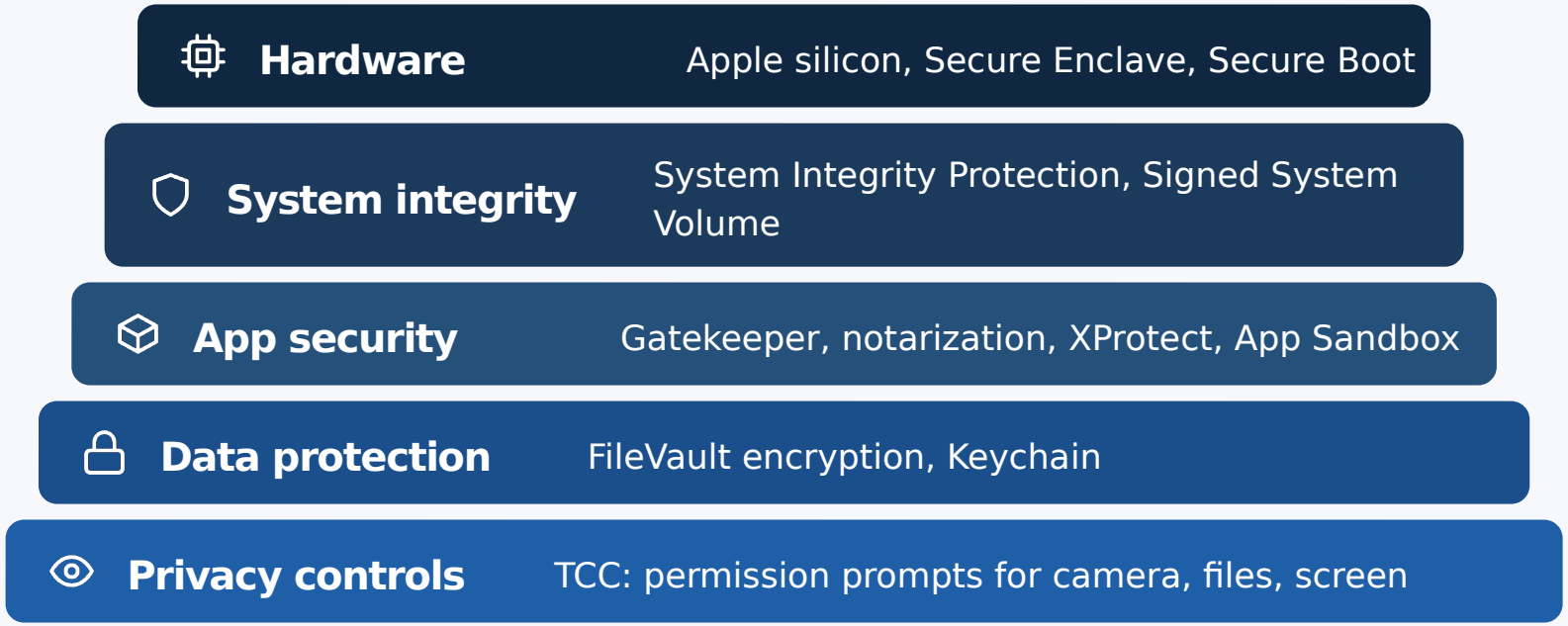
Fake apps and ads
Malvertising and cracked apps deliver malware disguised as popular tools.

Terminal paste tricks
ClickFix-style pages ask Mac users to paste commands into Terminal.

Fake password prompts
Malicious scripts pop up a convincing dialog asking for the Mac password.

Mac users are high-value targets: **executives, developers and finance teams** often use Macs.

macOS has strong security built in



THE CATCH

These protections only help if they stay switched on and enforced.

Source: Apple Platform Security Guide

macOS hardening framework

01

Device management

Enroll every Mac in MDM

02

Identity and accounts

Standard users, strong auth

03

Patching

Enforced, on-time updates

04

App control

Only trusted software runs

05

Data protection

Encryption and backups

06

Network

Firewall and sharing off

07

Monitoring

Logging, EDR and alerts

GOAL

Every Mac managed, verified and monitored

Aligned with CIS Benchmarks and NIST mSCP

Start with MDM: you can’t harden what you don’t manage

Automated Device Enrollment

Macs from Apple Business Manager enroll on first boot

Non-removable MDM profile

Users can't unenroll and escape policy

Configuration profiles

Push security settings centrally

Declarative Device Management

Devices enforce and report their own state

Compliance checks

Block access from non-compliant Macs

Remote lock and wipe

For lost, stolen or departing devices

Secure user and admin accounts

Standard user accounts

No everyday local admin rights

Just-in-time admin

Temporary elevation, approved and logged

Platform SSO

Sign in with the company identity and MFA

Auto-lock and password policy

Screen locks quickly; strong passwords

Guest and auto-login off

No anonymous or automatic access

Touch ID and passkeys

Phishing-resistant sign-in

Keep every Mac updated, on time

Enforce OS updates	Use DDM update deadlines, not just reminders
Fast security responses	Allow background security updates to apply automatically
Keep XProtect current	Automatic security data updates stay on
Patch third-party apps	Browsers, Office, Zoom, developer tools
Retire unsupported Macs	No security updates means no protection

Keep the built-in protections on

CONTROL	REQUIRED STATE	VERIFY WITH
System Integrity Protection	Enabled	`csrutil status`
Gatekeeper	App Store and identified developers	`spctl --status`
FileVault	On, key escrowed to MDM	`fdesetup status`
Firewall	On, with stealth mode	`socketfilterfw --getglobalstate`
Lockdown Mode	For high-risk users	`System Settings, Privacy and Security`

⚠ Enforce these through MDM, so users **can't switch them off**, and report their state centrally.

Control what runs, and what it can access

Gatekeeper and notarization

Block unsigned and un-notarized apps

App allowlisting

Approve apps via MDM; tools like Santa block the rest

PPPC privacy profiles

Control Full Disk Access, screen recording and accessibility

Managed app deployment

Install approved apps through MDM or the App Store

Watch scripts and Terminal

Alert on osascript password prompts and curl-to-shell

Train users

Never paste commands or enter passwords into pop-ups

Santa: open-source binary authorization for macOS · PPPC = Privacy Preferences Policy Control

Reduce the network attack surface

Firewall and stealth mode
Block unsolicited inbound connections

Disable unused sharing
Screen Sharing, Remote Login, File Sharing

Secure Wi-Fi profiles
802.1X and certificate-based networks

DNS and web filtering
Block malicious and newly registered domains

VPN or Zero Trust access
No direct exposure of internal apps

AirDrop for contacts only
Or off on managed Macs

Aligned with CIS Benchmarks for macOS

You can’t defend what you can’t see

EDR on every Mac
Built on Apple's Endpoint Security framework

Unified logging to SIEM
Forward key events centrally

New launch agents and daemons
The most common Mac persistence method

Privacy permission changes
New Full Disk Access or screen recording grants

Admin group changes
New or unexpected administrators

Gatekeeper overrides
Users bypassing app security warnings

Mac stealers often add a **LaunchAgent** for persistence. Alert on it.

Protect the data, even if the Mac is lost

FileVault everywhere

Full-disk encryption, recovery key escrowed in MDM

Activation Lock managed

Bypass codes stored in MDM for company Macs

Tested backups

Encrypted Time Machine or approved cloud backup

Removable media control

Restrict or block USB storage via MDM

Managed iCloud settings

Limit personal iCloud sync of company data

Secure decommissioning

Erase All Content and Settings before reuse

macOS hardening checklist

- 01 **Enrolled in MDM**
- 02 **macOS fully patched**
- 03 **Standard user account**
- 04 **SIP enabled**
- 05 **Gatekeeper enforced**
- 06 **FileVault on, key escrowed**
- 07 **Firewall and stealth mode on**
- 08 **Unused sharing disabled**
- 09 **EDR installed and reporting**
- 10 **Backups tested**

Automate checks with the **NIST macOS Security Compliance Project** and review after every major macOS release.

KEY TAKEAWAYS

Secure by default, only if it stays that way.

- Manage every Mac
- Remove everyday admin rights
- Enforce updates
- Keep protections on and verified
- Monitor for persistence

Thank you · Questions and discussion · Presented by ZNexora Tech